

ФУНДАМЕНТ ИТ · ДЕНЬ 28 ИЗ 30

Безопасность приложений

Различаем вход, права и безопасное хранение секретов.

Главная идея

Authentication отвечает на вопрос "кто вы?", authorization - "что вам разрешено?". Успешный вход не означает право видеть чужие данные.

```
cursor.execute(
    "SELECT id, title FROM courses WHERE
user_id = ?",
    (current_user_id, ),
)
```

План урока

Один блок теории - сразу практика и проверка.

1

Понять смысл

2

Выучить
термины

3

Разобрать код

4

Попробовать
самому

5

Собрать мини-
задачу

Как заниматься

Не читай как книгу. На практических слайдах остановись и попробуй решить сам.

Смысл темы простыми словами

Сначала бытовая идея, потом код.

Идея 1

Authentication отвечает на вопрос "кто вы?", authorization - "что вам разрешено?". Успешный вход не означает право видеть чужие данные.

Идея 2

Пароли хранят не открытым текстом, а в виде медленного криптографического хеша с солью. Секретные ключи не размещают в исходном коде и публичном репозитории.

Идея 3

Injection возникает, когда непроверенный ввод превращается в часть команды или SQL. Параметризованные запросы, проверка входа, минимальные права и обновление зависимостей снижают риск.

Термины дня

Эти слова нужно узнавать в коде и документации.

vulnerability

слабое место, которое можно использовать во вред

hash

одностороннее преобразование данных в фиксированное значение

authentication

проверка личности пользователя

authorization

проверка разрешения на конкретное действие

injection

внедрение пользовательского ввода в команду или запрос

secret

закрытое значение вроде ключа, токена или пароля

Код дня

Минимальный пример без лишней сложности.

```
cursor.execute(
    "SELECT id, title FROM courses WHERE user_id"
    = "?",
    (current_user_id,),
)
```

Что ищем

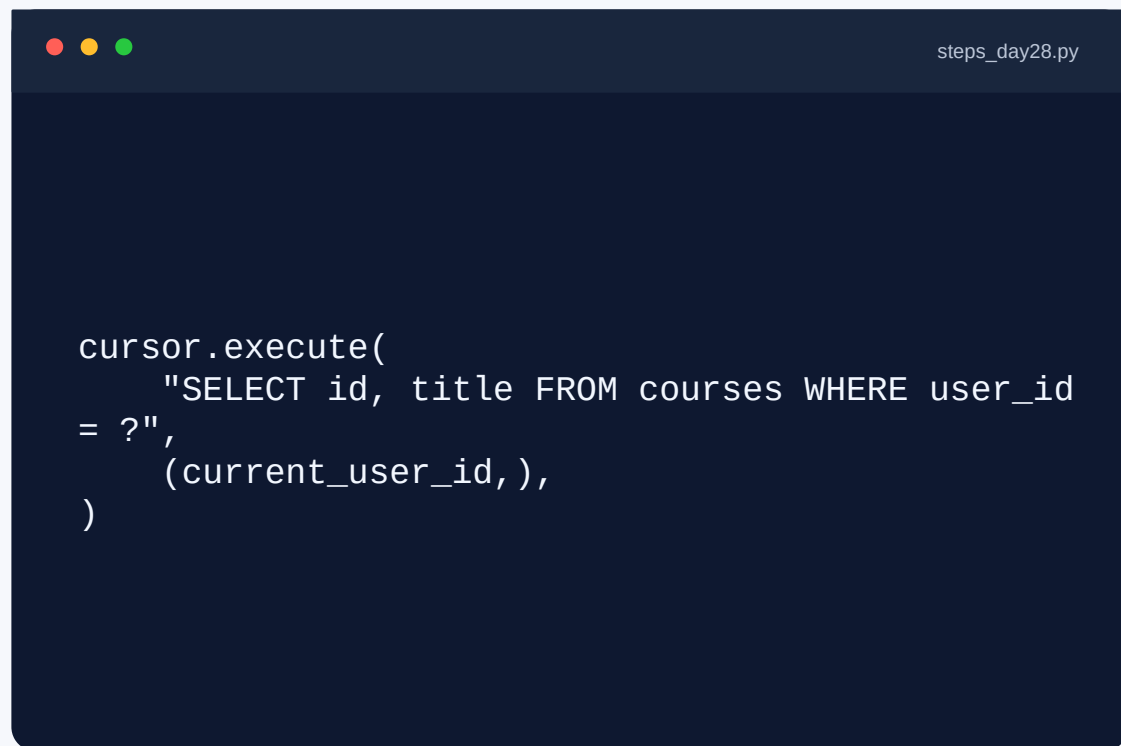
Где данные? Где действие? Где результат?

Главный вопрос

Можешь объяснить каждую строку обычным языком?

Разбор кода по шагам

Не переписываем вслепую.



```
cursor.execute(  
    "SELECT id, title FROM courses WHERE user_id  
= ?",  
    (current_user_id, ),  
)
```

- Прочитай строку сверху вниз.
- Назови данные, с которыми работает код.
- Объясни, какое действие выполняется.
- Проверь, какой результат должен получиться.



Важно

Если строка непонятна - остановись и переведи ее на обычный язык.

Практика: что произойдет?

Ответь без запуска кода.

```
question_day28.py

cursor.execute(
    "SELECT id, title FROM courses WHERE user_id"
    = "?",
    (current_user_id,),
)
```

Вопрос

Что программа сделает после запуска?

Подсказка

Ищи последовательность: входные данные -> действие -> результат.

Ответ и объяснение

Сравни со своим рассуждением.

Ожидаемая логика

Этот пример относится к теме: Безопасность приложений. Различаем вход, права и безопасное хранение секретов.

Почему так?

Python выполняет инструкции по порядку. Поэтому важно читать код сверху вниз.

Проверка себя

Если можешь объяснить без подсказки - тема закрепляется.

Практика: сделай руками

Небольшое задание по теме дня.

Задание

Проверь: секреты, SQL-запросы, права, сообщения ошибок.

Шаг 1

Создай простой файл или черновик.

Шаг 2

Напиши минимальный рабочий вариант.

Шаг 3

Запусти и проверь результат.

Мини-тест

Выбери ответ и объясни почему.

Вопрос

В чём разница между authentication и authorization?

A

Первая проверяет личность, вторая - право на действие

B

Первая шифрует CSS, вторая запускает Python

C

Это одинаковые процессы

D

Вторая нужна только без пароля

Ответ мини-теста

Проверяем не память, а понимание.

Правильный ответ

А: Первая проверяет личность, вторая - право на действие

Объяснение

Сначала система устанавливает личность, затем отдельно проверяет разрешение на ресурс или действие.

Частая ошибка новичка

Лучше заранее увидеть, где обычно ломается.

Ошибка

Пытаться запомнить формулировку, но не понимать, где это видно в коде.

Как исправить

После каждого термина придумай свой пример и найди его в коде.

Правило

Термин считается выученным, когда ты можешь объяснить его на бытовом примере.

Самостоятельная мини-задача

Напиши маленький код или схему почти с нуля.

Условие

Проверь: секреты, SQL-запросы, права, сообщения ошибок.

- Что программа получает?
- Что она должна сделать?
- Какой результат показать?
- Какие термины дня здесь применяются?

Разбор решения

После попытки сравни с этим подходом.

```
cursor.execute(
    "SELECT id, title FROM courses WHERE user_id
= ?",
    (current_user_id,)
)
```

Не один вариант

Твой код может отличаться. Главное - он решает задачу и читается.

Проверка

Запусти пример и объясни результат вслух.

Задание со звездочкой

Немного сложнее, но без новой темы.

Условие

Расширь практику дня: добавь проверку ошибки, 2-3 тестовых примера и короткое объяснение для README.

Подсказка

Не усложняй. Сделай маленькое улучшение и обязательно проверь его на примере.

Итог дня

Что должно остаться после урока.

- объяснять тему "Безопасность приложений" простыми словами
- узнавать главные термины дня
- читать короткий пример кода
- выполнять практику руками
- находить одну типовую ошибку
- формулировать следующий маленький шаг

Домашнее задание

Проверьте учебный проект: нет ли паролей в коде, параметризованы ли SQL-запросы, проверяется ли владелец данных, ограничены ли сообщения об ошибках.